ONE-PAGE BRIEF

Post-quantum cryptography review: zcash-swift-wallet-sdk @ 4895ee058da9

Client: Electric Coin Company (Zcash) — public repository (passive review) · Source: github.com/zcash/zcash-swift-wallet-sdk, commit `4895ee058da9` · Reviewed: 2026-11-04 19:42 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
Level 0 of 4
no post-quantum cryptography

FINDINGS
0 Critical **0** High **7** Medium
20 Low **4** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Key establishment: 10 + 5 − 8 = 7 → **too late**
Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

Medium QSI-2026-12973	**Quantum-vulnerable RSA key (2048-bit) in responsible_disclosure.md** What to do: Inventory and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/ composite form where the ecosystem supports it..
Medium QSI-2026-12972	**Quantum-vulnerable RedDSA: transaction and message signing (1 file(s))** preliminary What to do: Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum signature schemes as chains...
Medium QSI-2026-12981	**rsa 0.9.10 is affected by RUSTSEC-2023-0071 (CVE-2023-49092)** What to do: Upgrade to a fixed version (none published yet; see the advisory for mitigations).
Medium QSI-2026-12982	**rustls 0.23.42 is affected by GHSA-2mjx-qc3c-rqvc (RUSTSEC-2026-0285)** What to do: Upgrade to a fixed version (0.23.45).

23 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium transaction and message signing	RedDSA	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 25; unlikely to apply to this build: 16 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 9.

Static review of source code and manifests; files analysed: 205. No requests were sent to the owner's systems.

Full report, content SHA-256: `f60610c0fd09206ce2e4aaad78ee103215b2a01dfce8478b48eab66154fe87b9`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.